SIMATS ENGINEERING
ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Report Analysis
Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(**20 Mark).**

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..**(10 Marks)**

Code of Conduct:

I __D.Hasini/192425147__ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: D.Hasini

ANSWERS

1. Nmap scan of 192.168.1.10 (open ports HTTP 80, SSH 22, MySQL 3306, with OS and service versions) - security risks, exploitation and countermeasures. (20 Marks)

Report Analysis and Interpretation (25%)

The analyst ran a service and OS detection scan (for example `nmap -sS -sV -O 192.168.1.10`). The report shows that three network services are reachable and that their **version banners and the operating system are disclosed**. This is important because every version string can be matched against public vulnerability databases (CVE/NVD), so the report is effectively a shopping list for an attacker. The three findings are interpreted below.

Port / Service	What the report tells us	Significance
80/tcp HTTP	A web server is running and answers in clear text; server software and version are visible.	Web applications are the most common entry point; no encryption means traffic can be read or altered.
22/tcp SSH	Remote administration is open to the network; the OpenSSH version is visible.	Gives a direct path to a command shell if credentials are weak or the version is vulnerable.
3306/tcp MySQL	The database server accepts connections from the network.	Databases should never be directly reachable; this is the most serious finding because it holds the data.
OS and versions	Operating system and service versions are fingerprinted.	Enables exact matching to known exploits and shows whether patching is neglected.

Identification of Security Risks and Vulnerabilities (25%)

- **HTTP (80):** unencrypted traffic (sniffing and session hijacking); web flaws such as SQL injection, cross-site scripting, directory traversal, file upload and default or admin pages; outdated web server software with known CVEs; information leakage through banners.
- **SSH (22):** brute-force and credential-stuffing attacks; weak or reused passwords; root login enabled; user enumeration; vulnerabilities in old OpenSSH versions; stolen private keys.
- **MySQL (3306):** direct exposure of the database to the network; default, empty or weak root password; brute force; outdated server versions with privilege-escalation or remote-code bugs; excessive privileges allowing file read/write; unencrypted database traffic; data theft and tampering.
- **Overall:** an unnecessarily large attack surface and no sign of network segmentation; the three services together allow a chained attack.

How an attacker could exploit them (conceptual attack path):

- Scan and fingerprint the host, then look up the discovered versions for known exploits.
- Attack the web application (for example SQL injection) to read database credentials or user data, or exploit an outdated web component to gain a foothold.
- Connect directly to MySQL 3306 using stolen or guessed credentials, dump or modify the data and, if privileges allow, read/write files on the server.
- Brute-force or reuse the recovered passwords against SSH to obtain a shell, escalate privileges and move to other systems in the network.

Application of Cybersecurity Concepts and Countermeasures (30%)

- **Reduce the attack surface:** close every port that is not needed; allow only required sources through a host and network firewall (default deny).

- **MySQL:** bind to 127.0.0.1 or a private management address only; block 3306 from user networks; run *mysql_secure_installation*; strong unique passwords; least-privilege accounts per application; remove anonymous users and the test database; enforce TLS; disable remote root login; keep the server patched.
- **SSH:** key-based authentication, *PasswordAuthentication no*, *PermitRootLogin no*; restrict by IP or place behind a VPN/jump host; enable MFA; use fail2ban or rate limiting; update OpenSSH.
- **HTTP:** force HTTPS with a valid TLS certificate (redirect 80 to 443, HSTS); patch the web server and applications; hide version banners; deploy a web application firewall; validate input and use parameterized queries.
- **General (defence in depth):** regular patching and vulnerability scanning, network segmentation (database in an internal zone), IDS/IPS and central logging with alerts, secure configuration baselines (CIS benchmarks) and periodic penetration tests.

```
# Hardening examples
ufw default deny incoming
ufw allow 443/tcp
ufw allow from 192.168.1.0/24 to any port 22 proto tcp

# /etc/ssh/sshd_config
PermitRootLogin no
PasswordAuthentication no

# /etc/mysql/mysqld.cnf
bind-address = 127.0.0.1
require_secure_transport = ON
```

Technical Communication and Documentation (20%)

Port	Risk level	Main threat	Key countermeasure
3306 MySQL	High	Direct database access / data theft	Bind to localhost, firewall, least privilege, TLS
22 SSH	Medium-High	Brute force, weak passwords	Key-only login, no root, MFA, IP restriction
80 HTTP	Medium-High	Web exploits, sniffing	HTTPS, patching, WAF, secure coding

Conclusion: the scan reveals an exposed and poorly restricted host. The database port is the priority to close, followed by hardening SSH and securing the web service, then re-scanning to confirm that only required services remain open. *Note: the analysis is based on the findings described in the question; exact version numbers in the original report should be checked against CVE databases.*

2. GoPhish phishing campaign at ABC Technologies Pvt. Ltd. (40% clicked, 20% entered credentials, several downloaded a malicious attachment) - weaknesses and recommendations. (20 Marks)

Report Analysis and Interpretation (25%)

GoPhish is used to send safe, simulated phishing emails and record how every employee reacts. The report shows a **funnel of risky behaviour**:

Stage	Result	Meaning
Link clicked	40% of employees	Four in ten people trusted an unverified link.
Credentials entered	20% of employees	Half of those who clicked (20 of 40) also typed their username and password on a fake login page.
Attachment downloaded	Several users	Malware delivery would have succeeded for these users.

A real attacker needs only **one** successful victim, so a 40% click rate and a 20% credential-submission rate indicate a high organizational risk and a low level of security awareness. The report measures behaviour, not intent; the results are an opportunity to train, not to blame.

Identification of Security Risks and Vulnerabilities (25%)

- **Lack of awareness:** employees do not check the sender address, link destination (hover) or the unusual request.
- **Susceptibility to social-engineering triggers:** urgency, authority, fear or curiosity (typical phishing lures) override caution.
- **Credential entry on an unverified page:** the login page was not checked for the correct domain and HTTPS context; passwords can be harvested and reused.
- **Unsafe attachment handling:** opening files (macros, executables, archives) without verification.
- **Technical gaps indicated:** the phishing mail reached inboxes, so filtering, link protection and attachment sandboxing are weak; credentials alone probably give access (no MFA).
- **Cultural and process gaps:** no habit of reporting suspicious mail, no clear incident-reporting path, and no policy with consequences or support.

Application of Cybersecurity Concepts and Countermeasures (30%)

1. User awareness programs

- Mandatory onboarding and refresher training (at least yearly, plus short monthly micro-lessons) on spotting phishing: sender, link, grammar, urgency, unexpected attachments.
- Regular simulated phishing campaigns with immediate “teachable moment” feedback; extra coaching for repeat clickers; role-based training for finance, HR and administrators.
- A one-click “Report phishing” button and recognition for employees who report; track click rate (goal below 5%) and report rate.

2. Email and technical security controls

- SPF, DKIM and DMARC (enforced) to prevent domain spoofing; secure email gateway with spam/phishing filtering; URL rewriting and time-of-click checking; attachment sandboxing.
- Block or strip dangerous attachment types (executables, macro-enabled Office files, ISO/script files); add an “External sender” banner.
- **Multi-factor authentication** on all accounts so that stolen passwords alone are useless; password manager; DNS/web filtering; endpoint protection (EDR) and least-privilege accounts.

3. Organizational policies

- Email and acceptable-use policy; password and MFA policy; clear **incident reporting procedure** (report within minutes; who to call); incident response plan including forced password reset after a credential leak.
- A non-punitive reporting culture, with progressive coaching for repeated failures; verification procedures for payment or credential requests (call back on a known number).
- Periodic audits and management reporting of campaign metrics.

Technical Communication and Documentation (20%)

Weakness shown	Control recommended
Clicking unverified links (40%)	Awareness training, URL rewriting, report button
Entering credentials (20%)	MFA, password manager, check-the-URL training
Downloading attachments	Attachment filtering/sandbox, EDR, block macros
No reporting habit	Reporting policy, non-punitive culture, rewards

Conclusion: the campaign shows that people are the main attack surface. Combining training, email security and strict policies, followed by repeat campaigns to measure improvement, will lower the success rate of social-engineering attacks.

3. Dig report showing a successful DNS Zone Transfer (AXFR) - implications, exploitation and DNS security best practices. (10 Marks)

Report Analysis and Interpretation (25%)

The assessment used the *dig* tool, for example `dig axfr example.com @ns1.example.com`. A successful AXFR means the DNS server returned the **entire zone file** to an unauthorized requester. AXFR is meant only for replication between a primary and its secondary DNS servers; answering it for anyone is a misconfiguration. The report exposes internal hostnames, mail servers and other DNS records (A/AAAA, CNAME, MX, NS, TXT, SRV).

Identification of Security Risks and Vulnerabilities (25%)

- **Complete network map:** every host name and its IP address, including internal, test, development, VPN, database and admin servers that were never meant to be public.
- **Naming patterns and technology hints** (for example db01, vpn, dev, jenkins) that help attackers choose the weakest targets.
- **Mail infrastructure (MX, SPF/TXT) exposure** that supports targeted phishing and spoofing.
- **Forgotten or stale records** that can lead to subdomain takeover.

How attackers could use this: they skip the slow guessing phase of reconnaissance, pick high-value or poorly protected hosts, scan and attack them directly, launch spear-phishing using the real mail-server and staff-system names, hijack dangling subdomains, and plan attacks against the internal IP scheme.

Application of Cybersecurity Concepts and Countermeasures (30%)

- **Restrict zone transfers** to the IP addresses of authorized secondary servers (for example BIND *allow-transfer { 192.0.2.2; };*) and deny everyone else; block TCP/53 from other sources at the firewall.
- Secure transfers with **TSIG** keys so only authenticated servers can transfer.
- Use **split-horizon (split-view) DNS**: keep internal names only on internal DNS; publish only the necessary public records.
- Remove stale records, disable recursion for external clients, patch the DNS software, enable DNSSEC for integrity, and apply rate limiting.
- Monitor DNS logs for AXFR attempts and test regularly with dig that transfers are refused.

```
# named.conf (BIND) - restrict zone transfer
zone "example.com" {
  type master;
  file "db.example.com";
  allow-transfer { 192.0.2.2; };   # secondary only
};
# Verification (should return: Transfer failed / REFUSED)
dig axfr example.com @ns1.example.com
```

Technical Communication and Documentation (20%)

Finding	Impact	Fix
Zone transfer allowed to anyone	Full disclosure of hosts, IPs and mail servers	allow-transfer to secondaries only + TSIG
Internal names in public zone	Easy target selection	Split-horizon DNS
Stale records	Subdomain takeover	Regular DNS audit and cleanup

Conclusion: allowing AXFR to anyone hands the attacker the map of the organization. Restricting and authenticating transfers, separating internal and external DNS and monitoring the server closes this gap.

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.